

Improving Security Posture

Mostly subtraction. Removing permissions and credentials nobody needs.

Nobody remembers why a permission was granted. **Measure what is used, then remove the rest.**

Finding what is not used

- ◆ **Access Advisor** shows the services a principal was granted and when each was last accessed. Never accessed is a strong signal.
- ◆ **IAM Access Analyzer unused access** finds unused roles, keys, passwords, and unused actions within a role.
- ◆ **Access Analyzer policy generation** writes a least-privilege policy from CloudTrail activity, so you start from evidence.
- ◆ **The credential report** lists every user, key age, last use and MFA status, as a single CSV.

ON THE EXAM

Policy generation is the practical answer to "nobody knows what this needs". It reads the log rather than asking anyone.

The root user problem, and what changed

- ◆ **Every account historically had root credentials**, each needing a password, an MFA device and somewhere safe to store both.
- ◆ **Centralized root access management** lets you delete root passwords, access keys and certificates across member accounts.
- ◆ **New accounts in Organizations now have no root credentials by default**, and members cannot recover them unless you allow it.
- ◆ **Privileged root actions** cover the narrow set that genuinely needed root, notably deleting a deny-all S3 bucket or SQS queue policy.

ON THE EXAM

This is newer than most material. Two hundred accounts once meant two hundred root credentials and two hundred MFA devices.

Credential hygiene

- ◆ **Long-lived access keys on IAM users are the recurring finding.** Roles and Identity Center replace them, as in module four.
- ◆ **Secrets Manager rotation** can be retrofitted onto existing credentials without the application knowing, using its RDS integration.
- ◆ **Access Analyzer unused access** is the tool that finds keys nobody has used, which is where you start.
- ◆ Rotating a key that should not exist is the wrong fix. Ask whether the identity needs a key at all.

ON THE EXAM

An access key that has not been used in 400 days does not need rotating. It needs deleting, and that is a different conversation.

Data protection posture

- ◆ **Macie** discovers sensitive data you did not know you had, which is where a classification programme starts.
- ◆ **S3 default encryption and Block Public Access** can be applied account-wide, retrospectively, in one action.
- ◆ **Data residency** is an SCP on `aws:RequestedRegion`, with a Config rule as the evidence, exactly as in module two.
- ◆ Retention is a lifecycle policy plus Object Lock. Deleting data on time is part of posture too.

ON THE EXAM

You cannot classify data you cannot find. Macie answers what and where before anybody argues about controls.

Measuring whether it improved

- ◆ **Security Hub security standards** give a score per standard, so posture becomes a number that moves.
- ◆ **Config conformance packs** bundle rules into a named baseline, deployable across the organisation.
- ◆ Track the trend, not the absolute. A score of 71 rising is healthier than a score of 88 falling.
- ◆ A control with many exceptions is not a control. Count the exceptions as part of the measurement.

ON THE EXAM

Domain 3 is about improvement, and improvement needs a baseline. Without a number, nobody can tell whether anything got better.

Reading the scenario

THE SCENARIO SAYS

Roles have permissions nobody can justify

Nobody knows what permissions this app needs

Hundreds of root credentials and MFA devices

A bucket policy locked everyone out

Data must not leave a Region

We do not know where sensitive data is

IT IS POINTING AT

Access Advisor and unused access findings

Access Analyzer policy generation

Centralized root access management

Privileged root action to delete it

SCP on aws:RequestedRegion

Amazon Macie

ON THE EXAM

Most of these start with a question nobody can answer. Find the tool that answers it before choosing a control.

Meridian Freight has 140 accounts. Each has root credentials with a password stored in a shared vault and a physical MFA device in a safe. An audit found 12 accounts where the MFA device could not be located and 4 where nobody knew the password.

The company runs AWS Organizations with a dedicated security account.

What should the solutions architect recommend?

- ☐ A Enable centralized root access management, delete member account root credentials, and register the security account as delegated administrator
- ☐ B Reset all 140 root passwords and buy replacement MFA devices
- ☐ C Apply an SCP denying all actions by the root user
- ☐ D Document the root credentials in a central register reviewed quarterly

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A** Centralize and delete root credentials
Removes 140 sets of credentials rather than managing them. New accounts then have none by default, and the security account handles privileged tasks.
- B** Reset and re-buy
Restores the problem to a working state. There are still 140 passwords and 140 devices, and the same audit finding next year.
- C** SCP denying root
SCPs do not apply to the management account, from module two, and the credentials still exist to be stolen or misused.
- D** Central register
Improves record-keeping of credentials that should not exist. Documentation is not a control.

THE SIGNAL

The best security improvement is usually deletion. 140 credentials managed well are still 140 credentials.

A security review finds 60 IAM roles carrying AdministratorAccess. They were granted between 2019 and 2022. Nobody can explain most of them, and the owning teams refuse removal because they cannot prove nothing would break.

The company needs to reduce this without causing outages.

What should the solutions architect recommend?

- ☐ A Use Access Advisor and Access Analyzer unused access findings to identify what is actually used, then generate least-privilege policies from CloudTrail
- ☐ B Remove AdministratorAccess from all 60 roles and restore it where things break
- ☐ C Apply a permissions boundary to all 60 roles
- ☐ D Leave them and monitor with GuardDuty

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Measure use, then generate policies
Replaces an argument about intent with evidence about use. Policy generation produces a starting policy from what each role actually called.
- B

 Remove and see what breaks
Discovers dependencies through outages. It is also exactly why the teams are refusing, so it will not be agreed.
- C

 Permissions boundary on all 60
A useful ceiling, and it does not reduce what the roles are granted. The audit finding stands.
- D

 Monitor with GuardDuty
Detects misuse after it happens. Sixty administrator roles remain, which was the finding.

THE SIGNAL

The teams' objection is reasonable and evidence answers it. That is the whole argument for measuring before removing.

An engineer applies a bucket policy intended to restrict access, but the Deny statement is written incorrectly and now denies every principal, including administrators and the account itself. The bucket holds production data and nobody can modify the policy.

The company has centralized root access management enabled.

What should the solutions architect do?

- A Use a privileged root action from the management account or delegated administrator to delete the bucket policy
- B Recover the member account's root password and sign in as root
- C Open a support case to have AWS remove the policy
- D Recreate the bucket and restore the data from backup

◆ PAUSE AND DECIDE

What should the solutions architect do?

- A

 Privileged root action
Deleting a deny-all S3 bucket policy is one of the specific privileged actions this feature supports, done centrally with temporary credentials.
- B

 Recover root and sign in
The old answer, and it works. It also reinstates a credential you deliberately removed, for a task the feature now handles centrally.
- C

 Support case
Slower, and unnecessary. The account holds the capability to fix this itself.
- D

 Recreate and restore
Destroys and rebuilds a bucket because of a policy error. Data loss risk and downtime for a problem with a direct fix.

THE SIGNAL

This exact lockout is why privileged root actions exist. S3 and SQS deny-all policies are the two named examples.

A European bank must guarantee that customer data is never processed or stored outside eu-west-1 and eu-central-1. Engineers currently have access to all Regions. Compliance also needs continuous evidence for the regulator.

The company runs Control Tower across 60 accounts.

What should the solutions architect implement?

- ☐ A An SCP denying actions where `aws:RequestedRegion` is outside the two Regions, plus a Config rule providing continuous evidence
- ☐ B An IAM policy on each user restricting Regions
- ☐ C A Config rule that detects and deletes resources in other Regions
- ☐ D Disable unused Regions in the account settings

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

 SCP plus Config rule
The SCP refuses the API call so nothing is ever created elsewhere, and the Config rule supplies the continuous record the regulator wants.
- B

 IAM policy per user
Applies to the identities you remember to attach it to, and any new role or user starts unrestricted. It is a ceiling in the wrong place.
- C

 Detect and delete
The resource existed and processed data before deletion. Never is a preventive word, from module two.
- D

 Disable Regions
A real and useful control, and it applies per account and does not produce compliance evidence for the regulator.

THE SIGNAL

Guarantee plus continuous evidence is the same pair as module twenty five. Prevent with a policy, demonstrate with Config.

The credential report shows 210 IAM users with access keys. 90 keys have not been used in over a year. 40 belong to applications running on EC2. 30 belong to people who have left. The remainder are used by CI systems outside AWS.

Security has asked for a 90-day key rotation policy.

What should the solutions architect recommend?

- ☐ A Implement 90-day rotation across all 210 keys
- ☐ B Delete the unused and leaver keys, replace application keys with instance roles, and use IAM Roles Anywhere or OIDC federation for the external CI systems
- ☐ C Move all 210 keys into Secrets Manager with automatic rotation
- ☐ D Apply an SCP denying use of access keys

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Rotate all 210
Rotates 160 keys that should not exist, forever. It satisfies the letter of the request and improves very little.
- B

 Delete, replace, federate
Removes 120 keys outright, replaces 40 with roles that need no rotation, and federates the rest. Only 50 keys ever needed a policy.
- C

 All into Secrets Manager
Manages keys well that should have been deleted. It is option A with better storage.
- D

 SCP denying key use
Would break the CI systems that legitimately need to authenticate, with no replacement offered.

THE SIGNAL

The report is broken into four groups deliberately. Three of them need deletion or replacement, not rotation.

A regulator asks the company to state which of its 4,000 S3 buckets contain personal data. Nobody knows. Buckets have accumulated over nine years across 60 accounts, and naming conventions were never enforced.

The answer must be kept current, not produced once.

What should the solutions architect recommend?

- A Amazon Macie, run from a delegated administrator across the organisation, with scheduled sensitive data discovery jobs
- B Ask each account owner to complete a data classification questionnaire
- C A Config rule checking bucket tags for a data classification value
- D Enable S3 Block Public Access on all buckets

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

Macie across the organisation
Inspects the objects themselves rather than asking anybody, works organisation-wide from a delegated administrator, and can run on a schedule.
- B

Questionnaires
Asks people who do not know, about buckets created by people who have left. It produces a document, not a finding.
- C

Config rule on tags
Checks whether a tag exists, not whether it is true. An untrue tag passes the rule perfectly.
- D

Block Public Access
A good control, and it answers a different question. The regulator asked what the data is, not who can reach it.

THE SIGNAL

Nobody knows is the whole problem. Only inspecting the objects produces an answer; every other option asks somebody.

What to carry out of this module

- ◆ **Measure use, then remove.** Access Advisor, unused access findings and policy generation turn intent into evidence.
- ◆ **Centralized root access management deletes root credentials** across member accounts. New accounts have none by default.
- ◆ **Rotating a credential that should not exist is the wrong fix.** Ask whether it needs to exist at all.
- ◆ **Macie answers what and where.** You cannot classify data you cannot find, and questionnaires do not find it.

ON THE EXAM

Prevent with a policy, demonstrate with Config. That pairing has now appeared in modules two, ten, twenty five and here.